Business Continuity Plan Template

This enhanced template builds directly on the provided sample while incorporating current best practices (2025–2026) from NIST SP 800-34 Rev. 1, ISO 22301 (Business Continuity Management Systems), and cybersecurity-specific guidance tailored for modern threats. It is designed for CoolUnderFire Cybersecurity to customize and deliver to clients—emphasizing cyber resilience (ransomware, DDoS, supply-chain attacks, data breaches) alongside traditional disruptions (natural disasters, infrastructure failures).

1. Title Page

- **Document Title**: Business Continuity Plan (BCP) for [Company Name]
- **Prepared for**: [Company Name]
- **Prepared by**: CoolUnderFire Cybersecurity LLC
- **Date**: [Insert Date]
- **Version**: 1.0 (or current)
- **Confidentiality**: Restricted – For Internal Use Only

2. Executive Summary

Provide a high-level overview (1–2 pages) for executives. Summarize critical business functions, maximum tolerable downtime (MTD), key risks (with cyber emphasis), recovery objectives (RTO/RPO), and high-level strategy. Highlight how the plan ensures resilience against ransomware, breaches, and other incidents while minimizing financial/operational impact.

Best practice: Reference CoolUnderFire's cybersecurity services (e.g., managed detection/response, immutable backups) as enablers.

3. Introduction

a. Background

[Company Name] operates in [industry/sector]. This BCP ensures continuity of critical operations during disruptions, prioritizing safety, data integrity, and regulatory compliance (e.g., GDPR, HIPAA, CMMC if applicable). It integrates with the Incident Response Plan (IRP) and Disaster Recovery Plan (DRP).

b. Scope

This plan covers all [Company Name] locations, systems, and processes. It addresses natural, technological, human, and cyber threats. Out of scope: [e.g., full enterprise risk management].

c. Assumptions

©2026 CoolUnderFire Cybersecurity, LLC

- Key personnel are available or have backups.
- Backups follow 3-2-1-1-0 rule with immutable/air-gapped copies.
- CoolUnderFire or equivalent partners provide rapid support for cyber incidents.
- Alternate sites/cloud resources are pre-arranged.

4. Business Impact Analysis (BIA) & Risk Assessment *(New – Recommended Addition)*

a. Business Impact Analysis (BIA)

Identify critical processes, dependencies, and impacts. Use this table format:

Critical Process	Max Tolerable Downtime (MTD)	RTO (Recovery Time Objective)	RPO (Recovery Point Objective)	Dependencies (Systems, Vendors, Personnel)
[e.g., Client Portal Access]	4 hours	2 hours	1 hour	Cloud hosting, authentication system
[e.g., Email & Collaboration]	8 hours	4 hours	15 min	Microsoft 365 / on-prem servers

Best practice: Conduct BIA annually or after major changes. Prioritize based on revenue, reputation, regulatory impact.

b. Risk Assessment

Evaluate threats by likelihood and impact (include cyber-specific: ransomware targeting backups, DDoS, supply-chain compromise, insider threats). *Example threats & mitigations*:

- Ransomware: Air-gapped/immutable backups; do not pay ransom (per FBI guidance).
- DDoS: Redundant ISP/CDN; traffic scrubbing services.
- Natural disaster: Geographic diversity of data centers.

5. Concept of Operations

a. System Description

Describe key IT/OT systems, data flows, cloud/on-prem mix, and third-party dependencies (e.g., vendors managed by CoolUnderFire).

b. Overview of Three Phases

1. **Activation and Notification** — Declare incident and notify teams.
2. **Recovery** — Restore critical operations within RTO/RPO.

3. **Reconstitution** — Return to normal operations with validation.

c. Roles and Responsibilities

- **BCP Coordinator**: [Name/Title] – Overall ownership.
- **Incident Commander**: [Name] – Activates plan.
- **IT/Recovery Team**: Led by CoolUnderFire or internal IT (includes cyber experts).
- **Communications Lead**: Handles internal/external messaging.
- **Senior Leadership**: Approves recovery declaration. *Best practice*: Include alternates and 24/7 contact matrix in appendices.

6. Activation and Notification

a. Activation Criteria and Procedure

Activate if:

1. Major cyber incident (e.g., ransomware encryption detected);
2. System outage exceeding RTO thresholds;
3. Natural disaster impacting facilities.

Procedure: Incident Commander assesses via Outage Assessment (below) and declares activation.

b. Notification

Use automated tools (e.g., mass notification system, Slack/Teams escalation, phone tree). Notify within 15–30 minutes. Include regulators/clients if required (e.g., data breach notification laws).

c. Outage Assessment

Rapid evaluation (within 1 hour) of impacted systems, data loss, and cyber indicators (e.g., anomalous activity logs).

7. Recovery

a. Sequence of Recovery Activities

Prioritized by BIA (Tier 1 critical systems first). Example sequence:

1. Isolate compromised systems (cyber incidents).
2. Restore from clean, immutable backups.
3. Failover to alternate sites/cloud.
4. Test restored systems.

©2026 CoolUnderFire Cybersecurity, LLC

b. Recovery Procedures

Cyber-Specific:

- **Ransomware**: Disconnect from network, use air-gapped backups, forensic imaging before restore, post-restore malware scan/hardening.
- **DDoS**: Activate scrubbing/CDN failover.
- **Data Breach**: Containment per IRP, notification per law.

- Use runbooks/checklists (appendices) with step-by-step instructions, including automation/scripts where possible.
- Leverage CoolUnderFire services for threat hunting, secure recovery validation.

c. Recovery Escalation Notices/Awareness

Escalate to leadership if RTO at risk. Notify clients/partners per communication plan.

Best practice: Automate failover; test restores quarterly.

8. Reconstitution

a. Validation Data Testing

Verify restored data integrity (hashes, checksums) and absence of malware.

b. Validation Functionality Testing

End-to-end testing of business processes in restored environment.

c. Recovery Declaration

Leadership declares recovery complete when operations meet defined criteria.

d. Cleanup

Remove temporary workarounds; sanitize environments.

e. Offsite Data Storage / f. Data Backup

Maintain 3-2-1-1-0 rule with immutable (e.g., WORM storage) and air-gapped backups. Regular testing required.

g. Event Documentation

Log all actions, decisions, and lessons learned.

h. Deactivation

Formal handoff back to normal operations; archive incident documentation.

©2026 CoolUnderFire Cybersecurity, LLC

9. Plan Testing, Training, and Exercises (TT&E)

a. Testing

- Quarterly tabletop exercises (cyber scenarios emphasized).
- Semi-annual functional/drill tests (backup restores, failover).
- Annual full-scale simulation.

b. Training

Annual training for all staff on roles, phishing awareness, secure remote work (Zero Trust, MFA, VPN). CoolUnderFire can provide tailored sessions.

c. Exercises

Simulate ransomware, DDoS, supply-chain attacks. Include leadership decision-making under pressure.

d. TT&E Program Summary

Track metrics (e.g., time to recovery in tests); update plan based on findings. Document in appendices.

Best practice: Align with ISO 22301—measure effectiveness and continuous improvement.

10. Plan Maintenance

- **Review Cycle**: Annual full review + after any major change, incident, or test.
- **Version Control**: Track changes with approval by BCP Coordinator.
- **Distribution**: Secure, versioned copies to key personnel; CoolUnderFire can manage centralized repository.
- **Post-Incident Review**: Lessons learned incorporated within 30 days.
- **Continuous Improvement**: Integrate feedback from risk assessments and emerging threats.

11. Appendices

Expand with Client-Specific Content

A. Contact Lists (Key Personnel, Alternates, Vendors, CoolUnderFire Support, Regulators)

B. Critical Resources Inventory & Recovery Runbooks/Checklists

C. BIA/RTO/RPO Detail Tables

D. Communication Templates (Internal Alerts, Client Notifications, Media Statements)

E. Vendor/Supplier SLAs & Contingency Agreements

F. Backup & Restoration Procedures (including 3-2-1-1-0 validation)

©2026 CoolUnderFire Cybersecurity, LLC

G. Testing Logs & After-Action Reports

H. Glossary & References (NIST SP 800-34, ISO 22301, IRP linkage)

I. Legal/Compliance Considerations

Next Steps for CoolUnderFire Clients:

1. Conduct or update BIA/Risk Assessment (CoolUnderFire offers facilitated workshops).
2. Implement/improve backups and monitoring.
3. Schedule initial TT&E.
4. Integrate with existing IRP/DRP.

This template positions [Company Name] for greater resilience while leveraging CoolUnderFire's cybersecurity expertise to reduce downtime, protect against evolving threats, and maintain client trust. Contact CoolUnderFire for customization, implementation support, or managed services.

Version History

Date	Version	Updated by	Detailed changes
5/9/26	1.0	Andrea Cooley	Initial draft

©2026 CoolUnderFire Cybersecurity, LLC